TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

"cwpdoor" log-evading backdoor found in Control Web Panel web server

From **Cybersecurity Briefing** · 2026-11-08 to 2026-11-09 (stretched to 2026-11-04) · Briefing generated 2026-11-09

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261112-01	1.0 · 2026-11-12 15:02 EST	TLP:CLEAR	Global
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-05	No update	None	Nick Sturgeon

MALWARE | HIGH | SEEN IN THE WILD (ONE CONFIRMED VICTIM UPLOAD; SCALE UNKNOWN) | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

QiAnXin XLab disclosed on 5 November 2026 a Linux backdoor it calls cwpdoor. It is not a separate malware file: the attacker took the source of cwpsrv, the nginx-based web server that runs the Control Web Panel (CWP) admin interface, added two functions, recompiled it and swapped it in for the real binary at /usr/local/cwpsrv/bin/cwpsrv. The server keeps working normally. When a request arrives with three X-Ngx-Integrity headers carrying a fresh timestamp, an AES-256-CBC encrypted command and a valid RSA signature, the backdoor runs the command through a helper child process, returns the encrypted output and removes the request from access logging [S1] [S3].

The installer, a shell script named cwpsrv_update.sh that poses as a version update, was captured by XLab on 29 June 2026. It handles only cwpsrv 1.15.10 and 1.24.0, needs root, downloads the matching binary from 136.0.141[.]71, swaps it in, then restores the file and directory timestamps, deletes its temporary files and the backup, and removes its line from shell history. Because root is required, any host with cwpdoor was already fully compromised by some other means; XLab does not know how the attackers got in [S1] [S2]. An archive named evidencia.tgz uploaded to VirusTotal from Brazil on 30 September 2026 contained a copy of the backdoor (0 of 63 detections at the time) alongside an Ebury library, which XLab takes as evidence of at least one real victim. Whether Ebury and cwpdoor belong to the same actor is not known [S1] [S4].

XLab counted more than 340,000 internet-exposed CWP instances in the past month, with the United States the largest share; these are

potential targets, not infections, and no infection count has been published by XLab [S1] [S4] [S6]. One smaller outlet states more than 2,000 confirmed compromised servers and attributes it to XLab, but that figure does not appear in the XLab report or in any other coverage reviewed and should not be relied on [S7]. No CVE is associated with cwpdoor. All technical detail comes from a single vendor; the press coverage restates it without independent analysis.

Action: on every CWP host, run XLab's three checks (Unix socket, helper process, strings in the binary) and compare the cwpsrv MD5 against the three published hashes. A clean access log, a clean antivirus scan and unchanged file timestamps prove nothing here. If any check is positive, isolate the host, preserve evidence, treat the whole server as compromised, hunt for other implants such as Ebury, rotate all panel, SSH, database and application credentials, and rebuild from trusted media if integrity cannot be established [S1] [S5].

Key judgments

LIKELY · MODERATE CONFIDENCE
It is likely that more cwpdoor infections exist than the single Brazilian case, because the installer has automated version checks, rollback and result reporting to the download server, which points to repeated operational use rather than a one-off test. [S1] [S3]

LIKELY · LOW CONFIDENCE
It is likely that the operators hold or will build trojanized binaries for cwpsrv versions other than 1.15.10 and 1.24.0, and will change the header names, socket name and download server now that these are public, so the published checks will lose value over the coming weeks. [S1] [S5] [S6]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that initial root access in these intrusions came from known CWP command-injection flaws already in the CISA KEV catalog (CVE-2025-48703, CVE-2022-44877) or from stolen credentials, rather than from an undisclosed vulnerability. XLab makes no such link. [S1] [S6] [S9] [S10]

VERY LIKELY · MODERATE CONFIDENCE
It is very likely that endpoint and antivirus detection of the three known samples will improve quickly after publication, but hash-based detection will be easy to defeat by recompiling, so behavioral checks (socket, child processes, binary integrity against a vendor copy) will remain the dependable method. [S1] [S5]

UNLIKELY · MODERATE CONFIDENCE
It is unlikely that upgrading CWP alone closes the risk on a host that was infected, because the vendor has published no fix or statement tied to cwpdoor and the original entry point is unknown. [S5] [S6]

INDICATORS OF COMPROMISE

All indicators originate from the QiAnXin XLab report of 5 November 2026 (installer captured 29 June 2026, victim archive uploaded 30 September 2026) and were cross-checked against press coverage. They are single-vendor, several months old at the infrastructure level, and easy for the operator to change; derived entries are marked and explained.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
md5	`e505d4ffa21cf494a5dc2d7c8f4f1236`	Installer shell script cwpsrv_update.sh.	REPORTED	2026-06-29	[S1] [S2]
md5	`965aea67fb40de1bab5169ada993349f`	Backdoored cwpsrv 1.15.10 (x86-64 ELF, dynamically linked).	REPORTED	2026-06-29	[S1] [S2]
md5	`d3f4e95113d49ab3991b45e457bda75b`	Backdoored cwpsrv 1.24.0.	REPORTED	2026-06-29	[S1] [S2]
ipv4	`136[.]0[.]141[.]71`	Download server for the installer and both trojanized binaries; the installer also reports its result back to this address.	REPORTED	2026-06-29	[S1] [S2]
url	`hxxp[://]136[.]0[.]141[.]71/static/cwpsrv_update[.]sh`	Installer download URL. XLab lists the scheme as http; The Hacker News prints https. Match on host and path regardless of scheme.	REPORTED	2026-06-29	[S1] [S2]
url	`hxxp[://]136[.]0[.]141[.]71/static/cwpsrv_1[.]15[.]10`	Download URL of the backdoored 1.15.10 binary (scheme note as above).	REPORTED	2026-06-29	[S1] [S2]
url	`hxxp[://]136[.]0[.]141[.]71/static/cwpsrv_1[.]24[.]0`	Download URL of the backdoored 1.24.0 binary (scheme note as above).	REPORTED	2026-06-29	[S1] [S2]
filename	`cwpsrv_update.sh`	Installer script posing as a cwpsrv version update; must run as root.	REPORTED	2026-06-29	[S1] [S2]
filename	`cwpsrv_1.15.10`	Name of the trojanized binary as served by the download server.	REPORTED	2026-06-29	[S1]
filename	`cwpsrv_1.24.0`	Name of the trojanized binary as served by the download server.	REPORTED	2026-06-29	[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/usr/local/cwpsrv/bin/cwpsrv`	Legitimate binary path that the installer overwrites. The path is normal; the indicator is content that does not match the vendor build or that contains X-Ngx-Integrity strings.	REPORTED		[S1] [S5]
filepath	`/usr/local/cwpsrv/bin/cwpsrv.prev-YYYYMMDD-HHMMSS`	Backup of the original binary made by the installer (cwpsrv.prev-$(date +%Y%m%d-%H%M%S)). Deleted after a successful swap, so its presence suggests a failed or interrupted install. Do not trust a leftover copy without verifying it.	REPORTED		[S1] [S5]
other	`ngx_http_integrity_helper`	Unix domain socket (reported as an abstract socket by one outlet) used between cwpsrv and its command-running helper. Shown by: ss -axp | grep integrity.	REPORTED		[S1] [S2] [S4]
other	`cwpsrv child process titled "helper process"`	Extra child of cwpsrv, beside the normal master and worker processes, that executes attacker commands. Shown by: ps aux | grep cwpsrv.	REPORTED		[S1] [S4]
http-request	`X-Ngx-Integrity-Time`	Trigger header holding a timestamp; accepted within plus or minus 300 seconds of server time.	REPORTED		[S1] [S3]
http-request	`X-Ngx-Integrity-Data`	Trigger header holding the Base64 command blob: first 16 bytes are the IV, the rest AES-256-CBC ciphertext.	REPORTED		[S1] [S3]
http-request	`X-Ngx-Integrity-Sig`	Trigger header holding the Base64 RSA signature over "<time>:<data>".	REPORTED		[S1] [S3]
other	`ngx_http_integrity_init`	Function added to the trojanized binary (symbols were retained); sets up the socket and helper at configuration load. Useful as a strings or YARA term.	REPORTED		[S1]
other	`ngx_http_integrity_check`	Function added to the trojanized binary; inspects request headers at the start of request processing. Useful as a strings or YARA term.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`RSA public key stored XOR-encoded with single byte 0x55`	The embedded PEM public key is hidden with a one-byte XOR; the AES key is the SHA-256 of that key string. The full key is printed in the XLab report and can be used for a YARA rule.	REPORTED		[S1] [S4]
command	`history -d`	Used by the installer to delete its own entry from the current shell session's history.	REPORTED	2026-06-29	[S1]
filename	`evidencia.tgz`	Archive uploaded to VirusTotal from Brazil containing a cwpdoor sample and an Ebury library; evidence of a real victim, not an attacker tool name.	REPORTED	2026-09-30	[S1] [S4]
filename	`cwpsrv.suspeito`	Name given to the cwpdoor binary inside evidencia.tgz (Portuguese for "suspect", most likely named by the victim's responder). 0 of 63 detections at the time.	REPORTED	2026-09-30	[S1] [S3]
filename	`libkeyutils.so.1.5.2`	Ebury sample found in the same archive. Link to cwpdoor is unconfirmed. Note that libkeyutils is also a legitimate library name; version and hash mismatch against the distribution package is what matters.	REPORTED	2026-09-30	[S1] [S5]
http-request	`HTTP 200 response with Content-Type: application/octet-stream to a request carrying X-Ngx-Integrity-* headers`	Reported response format for command output. Seen only where TLS is inspected or traffic is cleartext.	REPORTED		[S1]
other	`Outbound connection from a CWP host to 136.0.141.71 on TCP 80 or 443`	Derived: the installer downloads from and reports back to this server, so any historical flow from a hosting server to it since mid-2026 is a strong lead. Both ports listed because sources disagree on the scheme.	DERIVED		[S1] [S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`cwpsrv binary whose hash differs from the vendor build while mtime and directory mtime look unchanged`	Derived: the installer restores atime/mtime on the binary and its parent directory, so timestamps cannot be used; ctime (change time) is not settable with touch and may still show the swap. Check with stat and compare the hash to a known-good copy of the same version.	DERIVED		[S1]
other	`Shell or interpreter processes whose parent is a cwpsrv process`	Derived: commands are executed by a helper forked from cwpsrv, so command children (sh, bash, curl, wget and similar) will have cwpsrv ancestry. This is an assumption about normal behavior; baseline first.	DERIVED		[S1]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

An attacker who already has root on a CWP server runs cwpsrv_update.sh. The script checks the installed cwpsrv version (1.15.10 or 1.24.0 only), downloads the matching trojanized build from 136.0.141[.]71, backs up the original, stops the service, overwrites /usr/local/cwpsrv/bin/cwpsrv, restarts it and confirms master, worker and helper processes are up, rolling back on failure. On success it deletes temporary files and the backup, restores access and modify times on the binary and its directory, removes its shell history entry and reports the result to the download server. The modified server adds ngx_http_integrity_init, which finds the logging module's index, creates the Unix socket ngx_http_integrity_helper and forks a helper, and ngx_http_integrity_check, which runs at the start of each request. A request with the three X-Ngx-Integrity headers is accepted only if the timestamp is within 300 seconds and the RSA signature over time and data verifies against an embedded public key (hidden with XOR 0x55). The command is decrypted with AES-256-CBC using a key derived from SHA-256 of the public key, passed to the helper over the socket and executed; output is returned encrypted in an HTTP 200 response. The request's module context is altered so the logging module skips it. No new listening port is opened [S1] [S3] [S4].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity

Tactic	Technique	Procedure observed	Detection opportunity
Persistence	T1554 Compromise Host Software Binary	The legitimate cwpsrv binary is replaced with a recompiled build that contains the backdoor, so it survives restarts and runs as part of the panel web server. [S1] [S2]	Compare the hash of /usr/local/cwpsrv/bin/cwpsrv with a vendor copy of the same version; run strings for X-Ngx-Integrity; file integrity monitoring on the cwpsrv bin directory.
Command and Control	T1105 Ingress Tool Transfer	The installer downloads the version-matched trojanized binary from 136.0.141[.]71/static/. [S1] [S2]	Search proxy, firewall and NetFlow history for connections from Linux hosting servers to 136.0.141.71.
Defense Evasion	T1036.005 Masquerading: Match Legitimate Resource Name or Location	The installer is named as a cwpsrv update and the implant sits at the genuine binary path with function names styled like nginx modules (ngx_http_integrity_*). [S1] [S6]	Alert on any cwpsrv replacement that does not coincide with an approved CWP update.
Defense Evasion	T1070.006 Indicator Removal: Timestomp	Access and modify times of the new binary and its parent directory are reset to the original values so ls and stat show nothing unusual. [S1] [S2]	Check ctime with stat; audit utimensat/touch calls against the cwpsrv path; rely on hashes rather than timestamps.
Defense Evasion	T1070.003 Indicator Removal: Clear Command History	The installer runs history -d to remove its entry from the session history. [S1]	auditd or EDR command-line logging for history -d by root; forward shell audit logs off-host.
Defense Evasion	T1070.004 Indicator Removal: File Deletion	Temporary files and the cwpsrv.prev-<timestamp> backup are deleted after a successful swap. [S1] [S2]	File creation and deletion events for cwpsrv.prev-* in /usr/local/cwpsrv/bin.
Defense Evasion	T1562.006 Impair Defenses: Indicator Blocking	For a trigger request the backdoor copies the request's module context array and replaces the logging module's entry, so no access log line is written. [S1] [S4]	Compare network-level records (load balancer, firewall, packet capture) of requests to the panel ports with cwpsrv access logs; unlogged requests are suspect.
Command and Control	T1205 Traffic Signaling	The backdoor stays passive and acts only on requests with the three signed X-Ngx-Integrity headers on the existing panel port. [S1] [S3]	Network signature on the header names where TLS is terminated or inspected in front of the panel.

Tactic	Technique	Procedure observed	Detection opportunity
Command and Control	T1071.001 Application Layer Protocol: Web Protocols	Commands and results travel inside ordinary HTTP/HTTPS requests and responses to the CWP web server. [S1]	Look for HTTP 200 application/octet-stream responses from the panel service to unfamiliar clients.
Command and Control	T1573.001 Encrypted Channel: Symmetric Cryptography	Commands and output are encrypted with AES-256-CBC; requests are authenticated with an RSA signature so only the key holder can use the backdoor. [S1] [S3]	Content inspection will not reveal commands; detect on header names and host artifacts instead.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	The installer is a Bash script, and the helper process executes arbitrary attacker commands with the privileges of cwpsrv. [S1] [S2]	Process lineage: shells or utilities spawned under cwpsrv.
Execution	T1559 Inter-Process Communication	The worker passes decrypted commands to the helper over the Unix domain socket ngx_http_integrity_helper. [S1] [S2]	ss -axp | grep integrity; periodic inventory of Unix sockets owned by cwpsrv.
Defense Evasion	T1027 Obfuscated Files or Information	The embedded RSA public key is stored XOR-encoded with 0x55 to avoid plain-text discovery. [S1] [S4]	YARA on the XOR-encoded PEM header and on ngx_http_integrity strings.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

cwpdoor installer download or execution (Linux process creation) `SIGMA`

```
title: cwpdoor Installer Download or Execution
status: experimental
logsource:
  category: process_creation
  product: linux
detection:
  sel_ip:
    CommandLine|contains: '136.0.141.71'
  sel_script:
    CommandLine|contains: 'cwpsrv_update.sh'
  sel_backup:
    CommandLine|contains: 'cwpsrv.prev-'
  condition: 1 of sel_*
falsepositives:
  - Administrators running the published checks or searching for these strings
level: high
```

Built from the installer name, download server and backup naming in the XLab report. Needs auditd or EDR command-line telemetry on the CWP host.

Shell or download utility spawned by cwpsrv `SIGMA`

```
title: Shell or Utility Spawned by CWP Web Server
status: experimental
logsource:
  category: process_creation
  product: linux
detection:
  parent:
    ParentImage|endswith: '/cwpsrv'
  child:
    Image|endswith:
      - '/sh'
      - '/bash'
      - '/dash'
      - '/curl'
      - '/wget'
      - '/python'
      - '/python3'
      - '/perl'
      - '/nc'
  condition: parent and child
falsepositives:
  - Unknown; baseline normal cwpsrv children on a clean host first
level: high
```

Derived from the helper-process design: commands run as descendants of cwpsrv. An nginx-based server does not normally spawn shells, but this has not been confirmed for CWP.

cwpdoor trigger headers in HTTP traffic `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"cwpdoor backdoor trigger header X-Ngx-Integrity"; flow:established,to_server; http.header_names;
content:"X-Ngx-Integrity-"; nocase; classtype:trojan-activity; reference:url,blog.xlab.qianxin.com/cwpdoor-the-invisible-backdoor-living-
inside-control-web-panel/; sid:1000901; rev:1;)
```

Only fires where the sensor sees decrypted HTTP (cleartext panel port or TLS terminated or inspected upstream). The same string can be used in a reverse proxy or WAF rule to block.

Connections to the cwpdoor download server and file events (Defender for Endpoint on Linux) `KQL`

```
let badIp = "136.0.141.71";
union
(DeviceNetworkEvents
 | where Timestamp > ago(30d)
 | where RemoteIP == badIp or RemoteUrl has badIp
 | project Timestamp, DeviceName, Source = "network", Detail = strcat(InitiatingProcessFileName, " -> ", RemoteIP, ":",
tostring(RemotePort)), InitiatingProcessCommandLine),
(DeviceFileEvents
 | where Timestamp > ago(30d)
 | where FileName == "cwpsrv_update.sh" or FileName startswith "cwpsrv.prev-" or MD5 in ("e505d4ffa21cf494a5dc2d7c8f4f1236",
"965aea67fb40de1bab5169ada993349f", "d3f4e95113d49ab3991b45e457bda75b")
 | project Timestamp, DeviceName, Source = "file", Detail = strcat(ActionType, " ", FolderPath), InitiatingProcessCommandLine)
| order by Timestamp desc
```

Advanced hunting retention is 30 days by default, so the June-September activity will only be visible in longer-retention stores (firewall, NetFlow, SIEM). Extend the window where data allows.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Control Web Panel (CWP) web server, cwpsrv	Hosts running cwpsrv 1.15.10 or 1.24.0 are the only versions the captured installer supports; other versions are unconfirmed. Infection requires prior root compromise.	No vendor fix or statement specific to cwpdoor. Replace the binary with a verified clean build and move to the current CWP release (1.30.1 of 2026-11-03 per press reporting).	None assigned	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Inventory every server running CWP, including client-owned and unmanaged VPS instances at third-party hosts, and record the cwpsrv version on each. `IT OPS` [S1] [S6]
- On each CWP host run XLab's checks as root: ss -axp | grep integrity (any ngx_http_integrity_helper result means infected); ps aux | grep cwpsrv (look for an extra helper child); strings /usr/local/cwpsrv/bin/cwpsrv | grep X-Ngx-Integrity (any hit means a trojanized binary). `SOC` [S1] [S2]
- Compute md5sum of /usr/local/cwpsrv/bin/cwpsrv and compare with the three published hashes and with a vendor copy of the same version. Do not rely on file timestamps, antivirus results or access logs. `SOC` [S1] [S5]
- Search firewall, proxy and NetFlow records back to June 2026 for any connection to 136.0.141.71 and block the address outbound. `SOC` [S1]
- If any check is positive: isolate the host, capture memory and disk evidence before changes, and open an incident. Treat the server and everything hosted on it as compromised at root level. `SOC` [S1] [S5]

Short term (1–7 days)

- On confirmed hosts, restore a legitimate cwpsrv (a leftover cwpsrv.prev-<timestamp> backup only after verifying its hash against a vendor copy), upgrade CWP to the current release and confirm the socket check returns nothing. Prefer a rebuild from trusted media, since the original entry point is unknown. `IT OPS` [S1] [S5]
- Rotate all credentials that touched the host: CWP admin and user accounts, root and SSH keys, database passwords, API keys, mail accounts and application secrets for hosted sites. Do it from a clean workstation. `IT OPS` [S1] [S4] [S5]
- Hunt the same hosts for other implants, in particular Ebury: verify libkeyutils and OpenSSH packages against the distribution's package database (rpm -V or equivalent) and review privileged logins and outbound connections. `SOC` [S1] [S5] [S8]
- Confirm CWP is patched past the KEV-listed command-injection flaws (CVE-2025-48703 fixed in 0.9.8.1205; CVE-2022-44877 fixed in 0.9.8.1147), since these are plausible routes to the root access the installer needs. `IT OPS` [S6] [S9] [S10]
- Tell affected customers or site owners if a shared hosting server is confirmed infected, and assess notification duties for any personal data hosted on it. `LEADERSHIP` [S5]

Long term

- Add file integrity monitoring and off-host hash baselines for control panel and web server binaries, and ship auditd or EDR process telemetry from Linux hosting servers to the SIEM. `SOC` [S1] [S5]
- Decide whether free, lightly supported hosting panels on unmanaged servers fit the organization's risk tolerance; plan migration to a supported platform or a managed service where they do not. `LEADERSHIP` [S6]
- Keep an independent record of requests to admin panels (reverse proxy, load balancer or firewall logs) so application log suppression can be detected by comparison. `IT OPS` [S1] [S4]

Workarounds & compensating controls

- Restrict the CWP admin and user panel ports (commonly 2030, 2031 and 2082-2087) to a VPN or an allow-list of management addresses. A passive backdoor cannot be triggered by an attacker who cannot reach the port. `IT OPS` [S5] [S7]
- Where the panel sits behind a reverse proxy or WAF, drop any request carrying a header whose name starts with X-Ngx-Integrity. `IT OPS` [S1] [S7]
- Apply default-deny outbound filtering on hosting servers so unexpected downloads and call-backs are blocked and logged. `IT OPS` [S5]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] QiAnXin XLab: cwpdoor: The Invisible Backdoor Living Inside Control Web Panel
Published 2026-11-05 · `A2` Completely reliable, probably true
Primary source and original researcher; origin of every indicator. Not independently reproduced.

[S2] The Hacker News: Hackers Hide Linux Backdoor in Control Web Panel Server to Execute Commands Without Logs
Published 2026-11-06 · `B2` Usually reliable, probably true
Briefing source. Restates XLab; prints download URLs with https where XLab has http.

[S3] BleepingComputer: Hackers backdoor Linux servers using trojanized CWP web server
Published 2026-11-05 · `B2` Usually reliable, probably true
Restates XLab; no vendor statement.

[S4] SecurityOnline (Daily CyberSecurity): cwpdoor backdoor in Control Web Panel
Published 2026-11-10 · `C2` Fairly reliable, probably true
Adds exposure breakdown from XLab data (342,591 instances; US 91,641, France 59,056, Germany 34,301) and Ebury detection count.

[S5] eSecurity Planet: CWPdoor Malware Detection and Removal: What Linux Server Admins Should Check
Published 2026-11-06 · `B2` Usually reliable, probably true
Practical response guidance; cautions that upgrading is not proof of a clean host.

[S6] webhosting.today: CWPdoor Replaces Control Web Panel's Web Server and Hides Attack Commands From Logs
Published 2026-11-06 · `C2` Fairly reliable, probably true
Notes absence of a CWP statement, recent CWP releases 1.29 and 1.30.1, and the two KEV-listed CWP CVEs.

[S7] Decryption Digest: cwpdoor Linux backdoor in cwpsrv (Control Web Panel)
Published 2026-11-09 · `C4` Fairly reliable, doubtful
Claims 2,000+ confirmed compromised servers attributed to XLab; not found in XLab's report or other coverage. Used only for CWP port list and to flag the disputed figure.

[S8] ESET WeLiveSecurity: Ebury is alive but unseen: 400k Linux servers compromised for cryptocurrency theft and financial gain
Published 2024-05-14 · `A1` Completely reliable, confirmed by other sources
Background on Ebury, which was found beside cwpdoor in the victim archive.

[S9] CVE Program (MITRE): CVE-2025-48703 record
Published 2025-09-19 · `A1` Completely reliable, confirmed by other sources
CWP unauthenticated command injection, CVSS 9.0, fixed 0.9.8.1205; CISA ADP data shows KEV addition 2025-11-04. Context only; not linked to cwpdoor.

[S10] CVE Program (MITRE): CVE-2022-44877 record
Published 2023-01-05 · `A1` Completely reliable, confirmed by other sources
CWP 7 unauthenticated command injection, CVSS 9.8, fixed 0.9.8.1147; KEV addition 2023-01-17. Context only; not linked to cwpdoor.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source

Date	Event	Source
2023-01-17	CISA adds CWP command injection CVE-2022-44877 to the KEV catalog (context; no stated link to cwpdoor).	[S10]
2025-11-04	CISA adds CWP command injection CVE-2025-48703 to the KEV catalog (context; no stated link to cwpdoor).	[S9]
2026-06-29	XLab's monitoring captures the installer cwpsrv_update.sh and the trojanized binaries for cwpsrv 1.15.10 and 1.24.0.	[S1]
2026-09-30	evidencia.tgz uploaded to VirusTotal from Brazil with a cwpdoor sample (0 of 63 detections) and an Ebury library.	[S1] [S4]
2026-10-31	CWP 1.29 released, moving cwpsrv to a newer nginx base; changelog does not mention cwpdoor.	[S6]
2026-11-03	CWP 1.30.1 security and stability update released; no reference to cwpdoor.	[S6]
2026-11-05	XLab publishes its analysis and indicators; BleepingComputer reports the same day.	[S1] [S3]
2026-11-06	The Hacker News, eSecurity Planet and webhosting.today publish coverage.	[S2] [S5] [S6]
2026-11-09	A smaller outlet reports 2,000+ confirmed infections; the figure is unsupported by the primary source.	[S7]
2026-11-10	Follow-up coverage adds the per-country exposure breakdown; no new indicators.	[S4]

Relevance to Indianapolis, Indiana & managed clients

CWP is a free panel most often found on low-cost, unmanaged VPS and dedicated servers, and the United States holds the largest share of exposed instances (about 91,600 of 342,600) [S4] [S6]. In Indiana the likely owners are small and mid-size businesses, web design and marketing agencies, regional hosting resellers, nonprofits, churches, school-affiliated groups and small municipal or county offices that host websites and mail outside their main IT environment. Larger healthcare, state government and manufacturing networks are unlikely to run CWP in core systems, but public-facing marketing sites, vendor portals and legacy department servers often sit on exactly this kind of host and fall outside patch and monitoring programs. For managed IT service clients the practical points are: ask every client whether any website, mail or DNS is hosted on a CWP server (including one run by a third-party web developer); run the three checks on any found; and remember that a root-level compromise of a shared hosting server exposes every site, mailbox and database on it, which can carry breach-notification duties under Indiana law if personal data is present. No Indiana victim has been reported.

Intelligence gaps

- Initial access: how the attackers obtain root on CWP hosts is unknown. Watch for XLab or others linking the campaign to a specific CVE or to credential theft.
- Scale: no reliable count of infected servers. The only confirmed victim evidence is one VirusTotal upload from Brazil.

- Actor: no attribution. The relationship to Ebury is unresolved.
- Version coverage: only 1.15.10 and 1.24.0 builds are known; whether builds exist for other cwpsrv versions is not known.
- Vendor position: CWP has not commented and has not said whether any release detects or removes the implant.
- Indicators: only MD5 hashes were published (no SHA-256), one IP and no domains. Current status of the download server is unknown and was not checked.
- Post-exploitation: no reporting on what commands the operators ran or what they did with access (data theft, spam, proxying, cryptomining).
- The CISA KEV JSON feed could not be read in full during research; KEV dates for the two context CVEs come from the CISA data embedded in the CVE records.

Other notes

- The briefing excerpt mentions "Ebury and an OpenSSH backdoor" in the victim archive. The XLab report lists two files only: the cwpdoor binary and libkeyutils.so.1.5.2 identified as Ebury. Ebury is itself an OpenSSH backdoor and credential stealer, so this is one item, not two [S1] [S8].
- Scheme discrepancy: XLab lists the download URLs as http; The Hacker News prints https. Hunt on host and path for both [S1] [S2].
- The 2,000+ infection figure in [S7] conflicts with every other source and with XLab, which gives no count. Treat as unverified.
- XLab's report does not indicate that CWP's own update channel was abused; the installer only imitates an update [S6].
- Publication date: XLab and BleepingComputer published on 5 November 2026; the briefing's 6 November date reflects The Hacker News coverage.
- The malicious download server was not contacted during research. No exploit or sample files were retrieved.

CTI-20261112-01 v1.0 · Generated 2026-11-12 15:02 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.